

Access Control Policy and Standard

NOVAtech Inc. | Simulated for demonstration

Document	Access Control Policy and Standard
Version	1.0
Owner	Head of Security
Approved by	Chief Technology Officer
Effective date	2026-08-03
Next review	Annually
Framework alignment	ISO/IEC 27001:2022 A.5.15, A.5.16, A.5.17, A.5.18, A.8.5; SOC 2 CC6.1-CC6.3; CIS Controls v8 Controls 5 and 6

1. PURPOSE

This document establishes requirements for granting, managing, reviewing, and revoking access to NOVAtech information systems and data. It combines policy (the principles that govern access) with standard (the specific, enforceable requirements that implement those principles).

2. SCOPE

Applies to all NOVAtech systems within the ISMS scope, all account types (employee, contractor, service, and privileged), and all personnel who grant, hold, or review access.

PART A - POLICY

The following principles govern access at NOVAtech and are binding on all personnel.

- A1.** Access to information and systems is granted on the principles of least privilege and need-to-know. Users receive the minimum access required to perform their role.
- A2.** All access is individually attributable. Shared or generic accounts are prohibited except where a documented technical constraint requires them, in which case compensating controls and an approved exception are mandatory.
- A3.** Access requires documented approval from the requesting user's manager prior to provisioning. Approval records are retained as audit evidence.
- A4.** Access is removed promptly when no longer required, whether through termination, role change, or completion of a time-bound engagement.
- A5.** Access rights are reviewed periodically by accountable system owners, with frequency determined by asset criticality.
- A6.** Privileged access is minimized, separately approved, time-bound where feasible, and monitored. Privileged accounts are distinct from daily-driver accounts.
- A7.** Authentication mechanisms are proportionate to the sensitivity of the information accessed. Multi-factor authentication is mandatory for all users.

PART B - STANDARD

The following requirements are enforceable and auditable. Deviations require an approved exception.

B1. Identity and authentication

- B1.1** All corporate applications SHALL authenticate through the central identity provider (Okta). Direct local authentication is prohibited where SSO integration is available.
- B1.2** Multi-factor authentication SHALL be enforced for all user accounts without exception. Phishing-resistant MFA (FIDO2/WebAuthn or equivalent) SHALL be required for all privileged accounts.
- B1.3** Passwords SHALL be a minimum of 14 characters and screened against known-breached password lists at creation and change. Forced periodic rotation SHALL NOT be applied in the absence of suspected compromise.

B1.4 Sessions SHALL expire after 12 hours of absolute duration and 2 hours of inactivity for systems handling Confidential or Restricted data. All active sessions and refresh tokens SHALL be invalidated on password change or credential compromise.

B2. Provisioning

B2.1 Access SHALL be requested through the designated ticketing workflow and SHALL NOT be provisioned without recorded manager approval. Verbal or chat-based approvals are not acceptable evidence.

B2.2 Provisioning SHALL follow predefined role templates where available. Requests for access outside a standard role template SHALL require additional approval from the system owner.

B2.3 Contractor and third-party accounts SHALL carry an expiry date not exceeding the contracted engagement period, with a maximum of 12 months before mandatory renewal review.

B3. Deprovisioning

B3.1 Access to all systems SHALL be deactivated within 1 business day of the termination date recorded in the HRIS.

B3.2 Role changes SHALL trigger review and adjustment of access within 5 business days. Accumulated access from prior roles SHALL be removed, not retained by default.

B3.3 Until automated HRIS-to-IdP deprovisioning is fully operational, a weekly reconciliation SHALL compare HRIS terminations against active identities, with exceptions remediated within 24 hours.

B4. Access reviews

Reviews SHALL be conducted at the following cadence, with named reviewers and retained evidence:

Asset criticality	Review frequency	Reviewer	Evidence
Critical	Quarterly	Named system owner	Signed attestation per user; revocation tickets
High	Semi-annually	Named system owner	Signed attestation per user; revocation tickets
Medium / Low	Annually	IT Manager	Bulk review record with exceptions noted
Privileged accounts (all)	Quarterly	Head of Security	Attestation plus justification for continued need

B4.1 Reviewers SHALL attest per user, not in bulk, for Critical and High systems. A reviewer who cannot justify a user's continued access SHALL flag it for revocation.

B4.2 Revocations identified during review SHALL be completed within 5 business days and evidenced.

B4.3 Review completion SHALL be reported to the Head of Security. Overdue reviews SHALL be escalated to the CTO after 15 business days.

B5. Privileged access

B5.1 Privileged accounts SHALL be individually named. Shared administrator credentials are prohibited.

B5.2 Privileged access SHALL be separate from the user's standard daily-driver account.

B5.3 All privileged sessions SHALL be logged, with logs forwarded to the central SIEM and retained for 12 months.

B5.4 Break-glass accounts SHALL exist for emergency access, be stored in a sealed credential vault, trigger an alert on use, and require post-use justification within 24 hours.

B6. Service accounts

B6.1 Every service account SHALL have a named human owner recorded in the service account inventory.

B6.2 Service account credentials and API keys SHALL be rotated at least every 12 months, and immediately on suspected compromise or owner departure.

B6.3 Service accounts SHALL be scoped to the minimum permissions required. Shared full-scope credentials across multiple services are prohibited.

3. EXCEPTIONS

Exceptions require written justification, compensating controls, Head of Security approval (CTO approval where the exception exceeds 90 days), and a defined expiry date. Exceptions are recorded in the Exception Register and reviewed monthly.

4. COMPLIANCE AND ENFORCEMENT

Compliance is verified through quarterly access reviews, periodic internal audit, and continuous monitoring of privileged access. Violations are handled per the Information Security Policy. Failures to meet the requirements in Part B are reportable as ISMS nonconformities.

5. RELATED DOCUMENTS

- Information Security Policy
- Acceptable Use Policy
- Asset Inventory (criticality classifications referenced in B4)
- ITGC Control Matrix (controls AC-01 through AC-04)
- Enterprise Risk Register (risk R-04)

6. CHANGE HISTORY

v1.0 (issued 2026-08-03): initial policy and standard. Establishes least privilege and need-to-know principles, MFA mandate, criticality-based review cadence, and privileged access requirements.